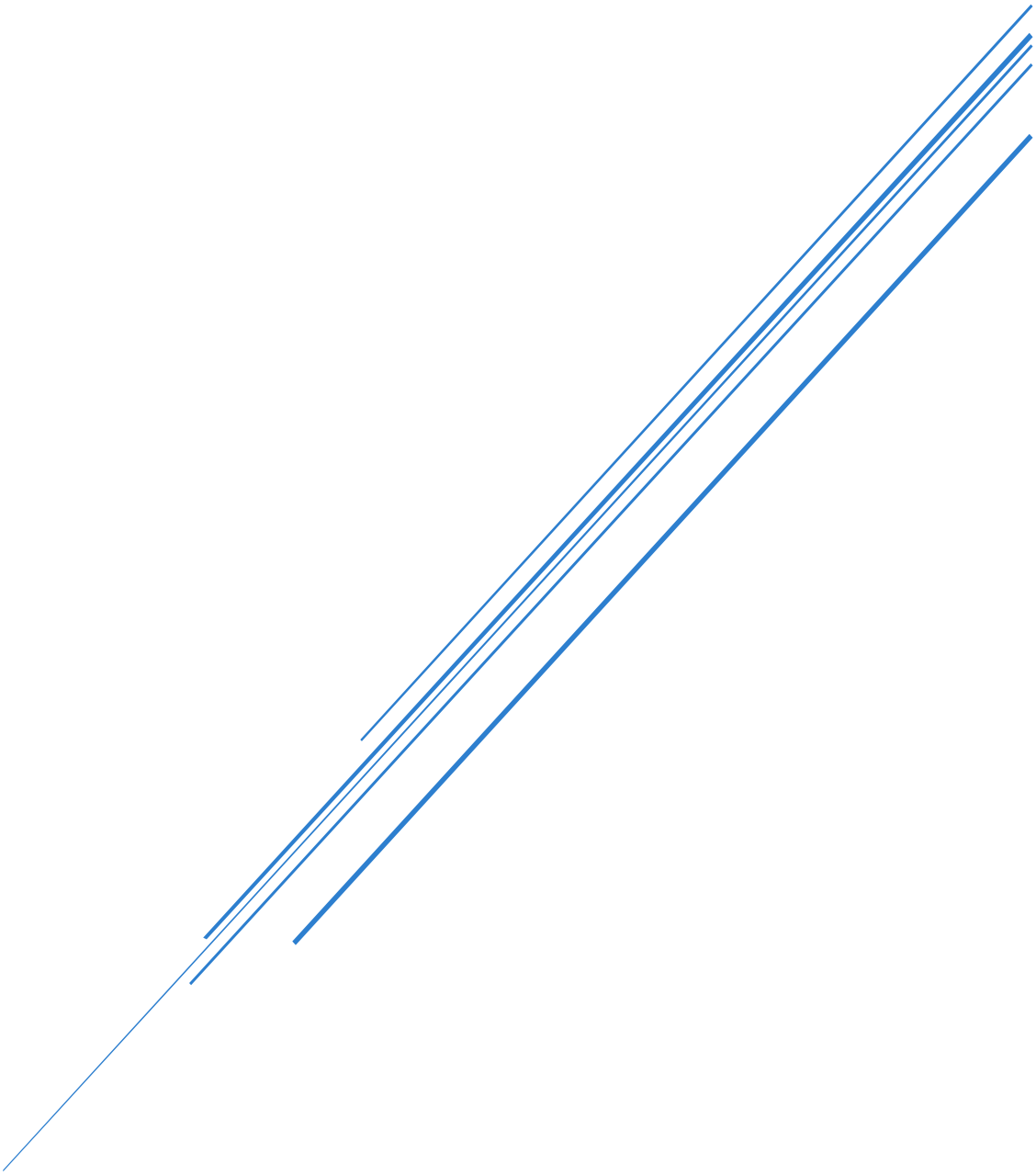
LABORATORIO SETTIMANALE

POWERSHELL, THREAT INTELLIGENCE (IOC) E BONUS: NMAP E SQL INJECTION



Davide

Epicode Institute of Technology - Cybersecurity & Ethical Hacking

19 giugno 2026

ESERCIZIO 1: USARE WINDOWS POWERSHELL

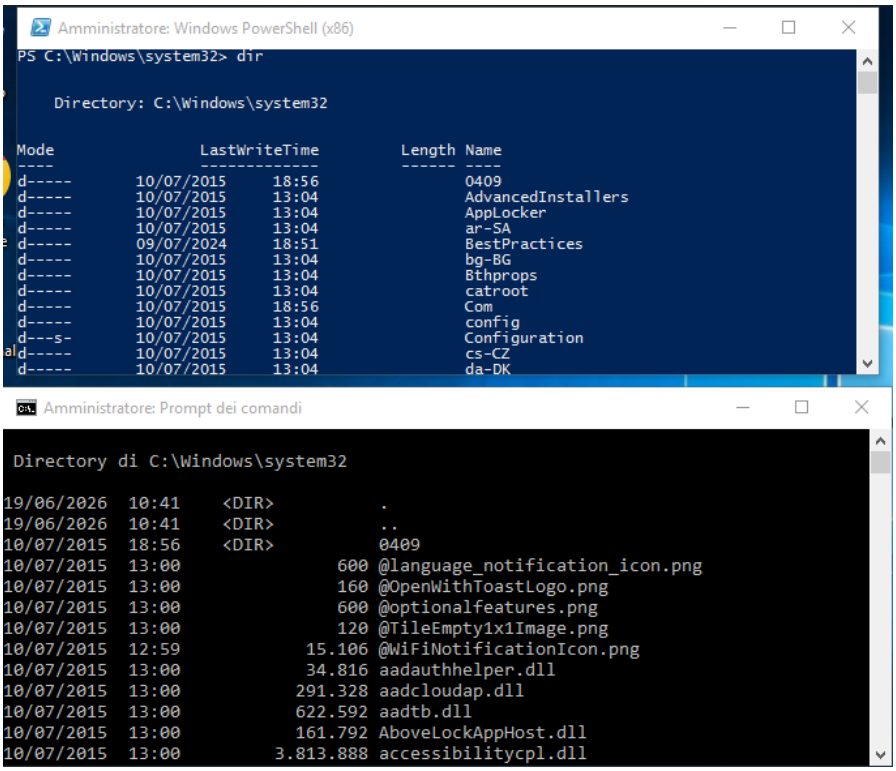
OBIETTIVO

L'obiettivo di questo laboratorio è esplorare alcune funzioni di base di Windows PowerShell: l'accesso alla console, il confronto con il Prompt dei Comandi, l'uso dei cmdlet, il comando netstat e la gestione del Cestino tramite script.

SVOLGIMENTO

PARTE 1 E 2: ACCESSO ALLA CONSOLE E CONFRONTO DEI COMANDI

Ho aperto sia PowerShell sia il Prompt dei Comandi ed eseguito il comando dir in entrambe le finestre per confrontare l'output.

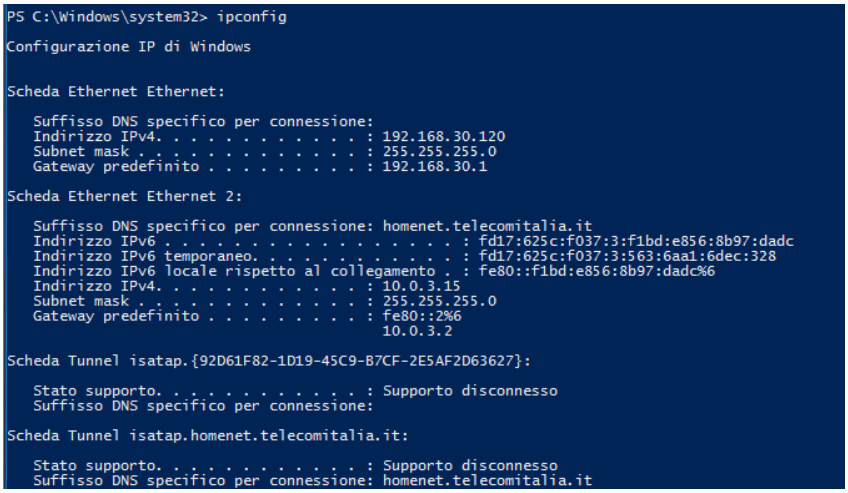


Confronto tra l'output di dir in PowerShell (sopra) e nel Prompt dei Comandi (sotto).

Quali sono gli output del comando dir?

In PowerShell l'output è organizzato in una tabella con colonne Mode, LastWriteTime, Length e Name, perché PowerShell tratta il risultato come oggetti con proprietà. Nel Prompt dei Comandi l'output è invece testo semplice, con data, ora, dimensione ed eventuale tag <DIR> per le cartelle. Il contenuto elencato è lo stesso, cambia solo il modo in cui viene presentato.

Ho poi provato un altro comando comune, ipconfig, per vedere se il comportamento è coerente anche al di fuori di dir.



Output di ipconfig in PowerShell.

Quali sono i risultati?

ipconfig funziona allo stesso modo in PowerShell e nel Prompt dei Comandi, perché non è un cmdlet nativo di PowerShell ma un eseguibile di sistema (ipconfig.exe). PowerShell, quando non trova un cmdlet con quel nome, richiama direttamente l'eseguibile esterno, quindi l'output resta testo semplice identico in entrambe le console.

PARTE 3: ESPLORARE I CMDLET

I cmdlet di PowerShell seguono la forma Verbo-Nome. Ho usato Get-Alias per controllare a quale cmdlet corrisponde il comando dir.



Get-Alias dir restituisce il cmdlet di riferimento.

Qual è il comando PowerShell per dir?

dir è un semplice alias del cmdlet Get-ChildItem, come conferma l'output di Get-Alias dir. È lo stesso meccanismo per cui ls in PowerShell punta sempre a Get-ChildItem.

PARTE 4: ESPLORARE IL COMANDO NETSTAT USANDO POWERSHELL

Ho controllato le opzioni disponibili con netstat -h, poi ho visualizzato la tabella di routing con netstat -r.

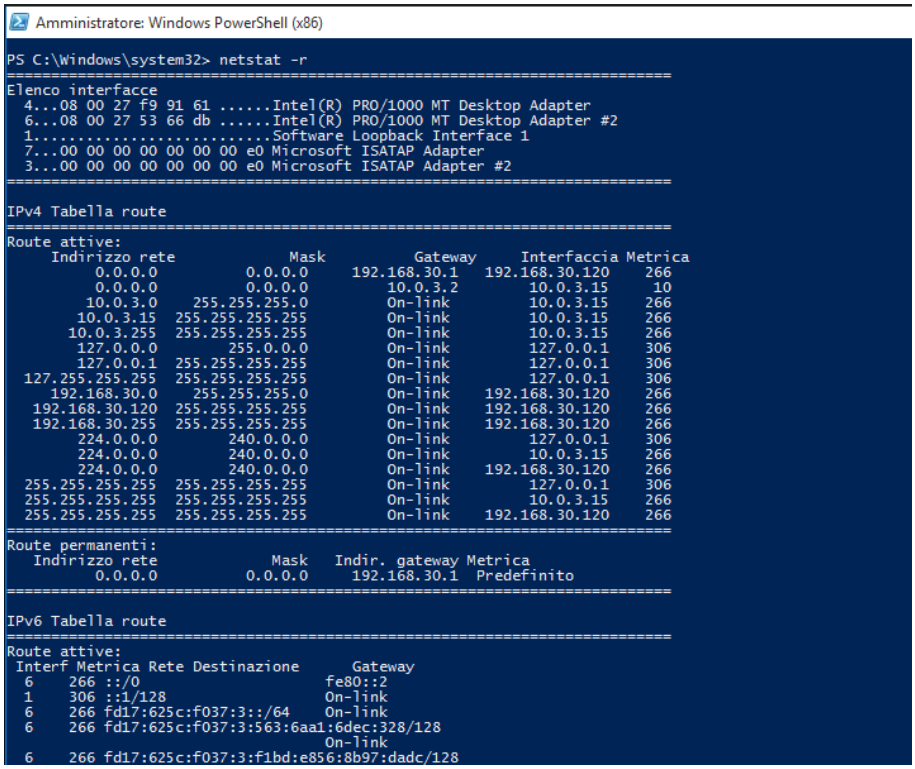
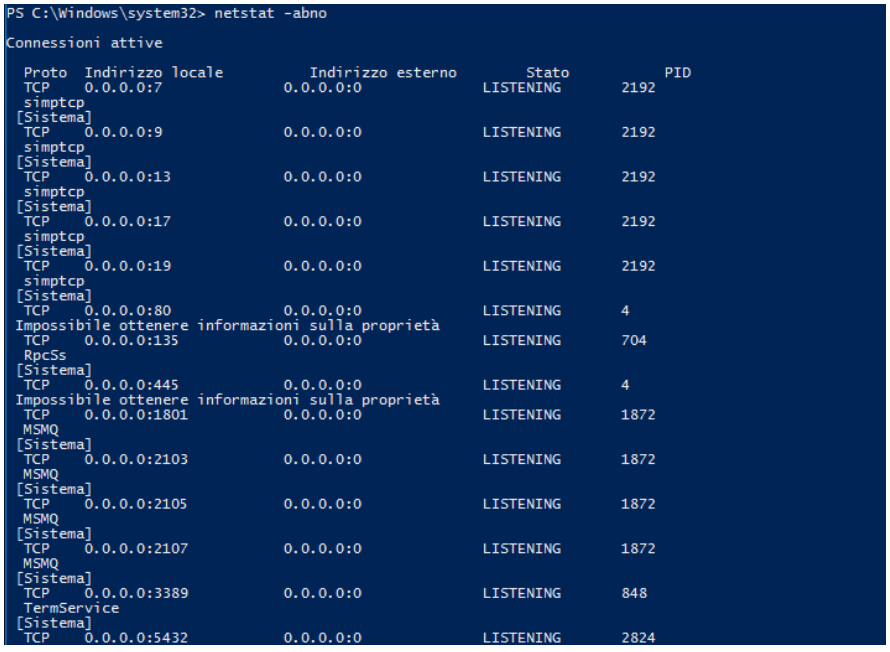


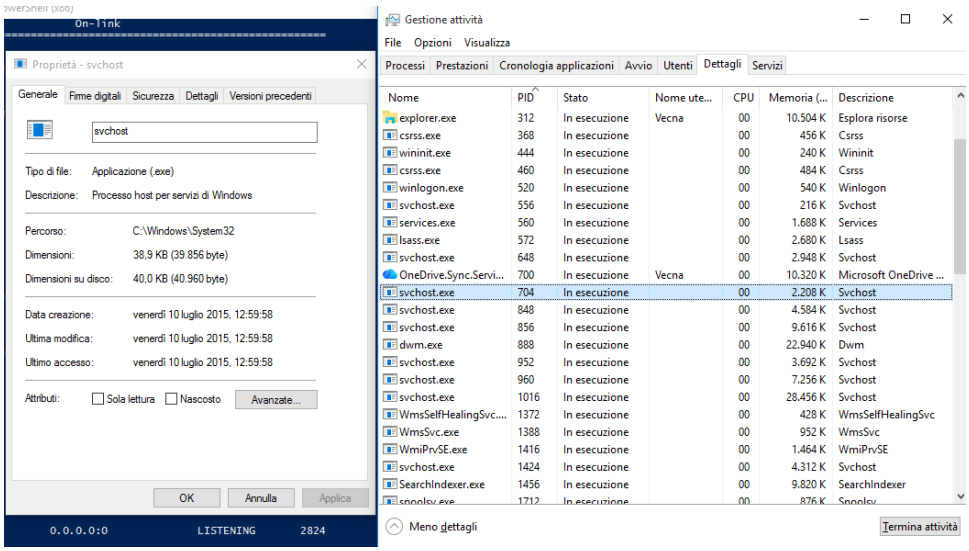
Tabella di routing IPv4 e IPv6 ottenuta con netstat -r.

Successivamente ho aperto una seconda finestra PowerShell con privilegi elevati ed eseguito netstat -abno per vedere tutte le connessioni TCP attive insieme al processo (PID) e all'eseguibile associati.



Connessioni attive con netstat -abno: porta, stato, PID e servizio associato.

Ho selezionato uno dei PID restituiti (il 704, associato a svchost.exe in ascolto sulla porta 135) e l'ho cercato in Gestione Attività, scheda Dettagli, per poi aprirne le Proprietà.



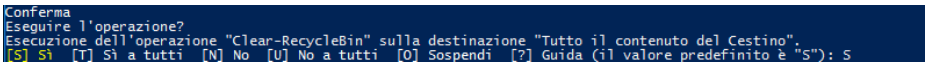
Proprietà del processo svchost.exe (PID 704) e relativa voce in Gestione Attività.

Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra di dialogo Proprietà per il PID selezionato?

Dalla scheda Dettagli di Gestione Attività si vede il nome del processo, l'utente che lo esegue, l'uso di CPU e memoria e una breve descrizione (in questo caso "Host Process for Windows Services"). Dalla finestra Proprietà si ottengono informazioni più approfondite sul file eseguibile: percorso completo (C:\Windows\System32), tipo di file, dimensioni su disco, date di creazione e ultima modifica, e dalla scheda Firme digitali si può verificare se il file è firmato da Microsoft, utile per capire se un processo è legittimo o sospetto.

PARTE 5: SVUOTARE IL CESTINO USANDO POWERSHELL

Per ultimo ho usato PowerShell per svuotare il Cestino in automatico, senza passare dall'interfaccia grafica, con il comando Clear-RecycleBin.



Conferma dell'operazione Clear-RecycleBin sul Cestino.

Cosa è successo ai file nel Cestino?

Dopo aver confermato con S (Sì), tutti gli elementi presenti nel Cestino sono stati eliminati in modo permanente, senza passare dall'icona sul desktop. Il comando chiede conferma proprio perché l'eliminazione è definitiva.

Domanda di Riflessione: come hai usato Internet per scoprire come usare PowerShell per semplificare i tuoi compiti come analista di sicurezza?

PowerShell è nato proprio per automatizzare attività di gestione e configurazione di Windows. Cercando online ho visto che, oltre ai comandi usati in questo laboratorio, un analista può scrivere script per controllare automaticamente i servizi attivi su più macchine, raccogliere log di sicurezza, individuare processi sospetti tramite PID e porta, o ripetere su larga scala azioni che a mano richiederebbero molto tempo, come il controllo delle connessioni di rete aperte su decine di host.

CONCLUSIONI

Questo laboratorio mi ha permesso di vedere PowerShell non solo come una console alternativa al Prompt dei Comandi, ma come un vero strumento di automazione: gli stessi comandi che ho usato per leggere connessioni di rete o svuotare il Cestino possono essere trasformati in script ripetibili. Per un analista di sicurezza questo è particolarmente utile per il triage rapido di un host, ad esempio per controllare in pochi secondi quali porte sono in ascolto e quali processi le usano.

ESERCIZIO 2: STUDIO IOC

OBIETTIVO

Analizzare un campione di malware tramite il sandbox online any.run e individuare gli indicatori di compromissione (IoC) e le minacce rilevate.

SVOLGIMENTO

Il task analizzato riguarda un file chiamato Jvczfhe.exe, scaricato da un repository GitHub (github.com/MELITERRER/frew). Il verdetto restituito da any.run è Malicious activity.

Il file è protetto con .NET Reactor, un tool che gli autori di malware usano per offuscare il codice e renderlo difficile da analizzare staticamente (è anche il motivo per cui il task è taggato "netreactor"). Una volta avviato, il file genera una copia di se stesso chiamata Muadnrd.exe, che si rilancia da sola: un classico meccanismo per garantirsi persistenza sul sistema.

Durante l'esecuzione il malware usa cmd.exe e timeout.exe per ritardare l'esecuzione, una tecnica di evasione delle sandbox automatiche, che analizzano un file solo per un tempo limitato. Lancia inoltre InstallUtil.exe, un eseguibile legittimo di .NET Framework, in modo anomalo: è una tecnica chiamata living off the land, cioè usare strumenti già presenti su Windows per eseguire codice malevolo senza dare nell'occhio agli antivirus. InstallUtil.exe si connette poi a una porta di rete insolita, probabile segno di comunicazione con un server di comando e controllo (C2).

Altri comportamenti osservati: il malware disabilita i log di trace di Windows (anti-forensics), controlla le impostazioni di trust di Windows e di Internet Explorer, e il processo va in crash più volte, intervento segnalato da WerFault.exe, probabilmente per un bug o come ulteriore tecnica di evasione.

Tra le richieste DNS catturate durante l'analisi compaiono diversi domini *.duckdns.org. DuckDNS è un servizio gratuito di Dynamic DNS, spesso sfruttato dai malware per nascondere l'indirizzo IP reale del server di comando e controllo: il nome a dominio resta fisso ma l'IP dietro può cambiare in continuazione, rendendo più difficile bloccarlo in modo definitivo.

INDICATORI DI COMPROMISSIONE (IOC)

- Nome file: Jvczfhe.exe (genera Muadnrd.exe)
- MD5: 00B5E91B42712471CDFBDB37B715670C
- SHA1: D9550361E5205DB1D2DF9D02CC7E30503B8EC3A2
- SHA256: 0307EE805DF8B94733598D5C3D62B28678EAEADBF1CA3689FA678A3780DD3DF0
- Sorgente di distribuzione: github.com/MELITERRER/frew
- Dominio C2 sospetto: *.duckdns.org
- Tag any.run: github, netreactor

CONCLUSIONI

Il campione analizzato è un malware loader/dropper distribuito tramite GitHub e protetto con .NET Reactor per ostacolare l'analisi statica. Una volta avviato si auto-rilancia per restare persistente, sfrutta strumenti legittimi di Windows per agire senza dare nell'occhio e comunica probabilmente con un'infrastruttura C2 nascosta dietro un dominio dynamic DNS. Questo comportamento è tipico dei loader usati come prima fase di un attacco, prima di scaricare ulteriori payload come infostealer o ransomware.

BONUS 1: ESPLORAZIONE DI NMAP

CONTESTO

La scansione delle porte fa solitamente parte di un attacco di ricognizione. Nmap è una utility di rete usata per la scoperta della rete e l'audit di sicurezza, e in questo laboratorio l'ho usata per scansionare il mio localhost, la mia rete locale e un host remoto.

SVOLGIMENTO

PARTE 1: ESPLORAZIONE DI NMAP

Ho consultato la pagina man di nmap (man nmap) per capire a cosa serve lo strumento e quali opzioni offre.

Cos'è Nmap? Per cosa viene usato?

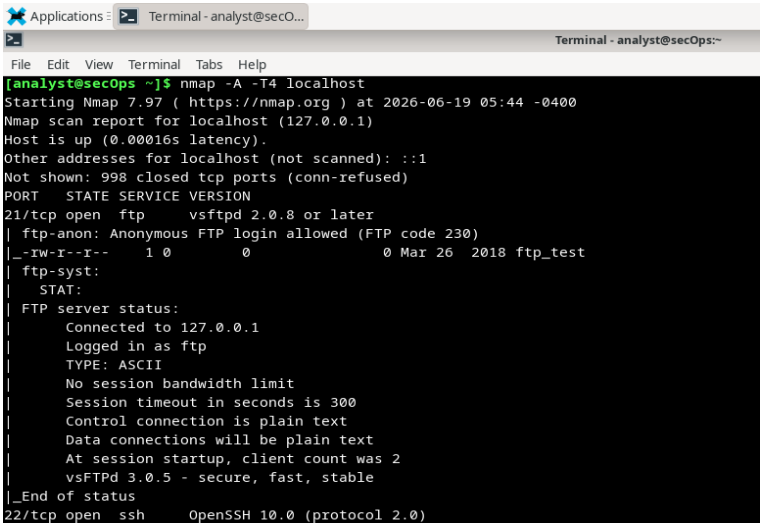
Nmap (Network Mapper) è un tool open source per l'esplorazione di rete e l'audit di sicurezza. Usa pacchetti IP per scoprire quali host sono attivi su una rete, quali servizi (nome e versione) offrono, quale sistema operativo usano e che tipo di firewall o filtri di pacchetti sono in uso.

Cosa fa l'opzione -A? Cosa fa l'opzione -T4?

-A abilita il rilevamento del sistema operativo e delle versioni dei servizi, lo script scanning e il traceroute, quindi raccoglie molte più informazioni in un solo comando. -T4 è un template di velocità che rende la scansione più aggressiva e veloce, limitando il ritardo massimo tra i pacchetti TCP a 10 millisecondi: utile su reti moderne e affidabili.

PARTE 2: SCANSIONE DELLE PORTE APERTE

Per prima cosa ho scansionato il mio localhost con nmap -A -T4 localhost.



Scansione nmap -A -T4 localhost: porte 21 (FTP) e 22 (SSH) aperte.

Poi ho recuperato l'indirizzo IP e la subnet della mia VM con ip address, per poter scansionare l'intera rete locale.

```
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
       valid_lft 85752sec preferred_lft 85752sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
       valid_lft 86142sec preferred_lft 14142sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
       valid_lft forever preferred_lft forever
```

Output di ip address: indirizzo IP 10.0.2.15/24.

A quale rete appartiene la tua VM?

La VM ha indirizzo 10.0.2.15 con subnet mask 255.255.255.0, quindi appartiene alla rete 10.0.2.0/24.

Ho quindi lanciato nmap -A -T4 10.0.2.0/24 per scansionare tutta la rete locale.

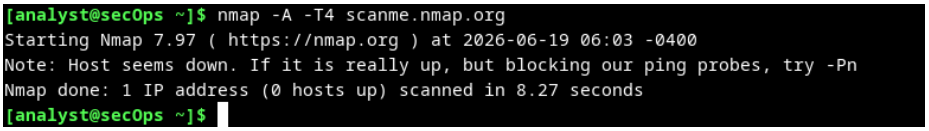
```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 05:53 -0400
Nmap scan report for 10.0.2.15
Host is up (0.000076s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 10.0.2.15
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--    1 0        0               0 Mar 26  2018 ftp_test
22/tcp open  ssh     OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome
```

Scansione della rete 10.0.2.0/24: porte e servizi rilevati sull'host 10.0.2.15.

Quanti host sono attivi? Quali porte e servizi sono aperti?

Nella mia subnet risulta attivo un solo host (10.0.2.15, la macchina stessa), con la porta 21 aperta (vsftpd, FTP anonimo consentito) e la porta 22 aperta (OpenSSH). Le altre 998 porte risultano chiuse.

Infine ho provato a scansionare l'host remoto scanme.nmap.org, il server messo a disposizione dal progetto Nmap per fare pratica.



Tentativo di scansione di scanme.nmap.org: l'host risulta down ai probe di Nmap.

Quali porte e servizi sono aperti? Qual è l'indirizzo IP del server? Qual è il sistema operativo? Qual è lo scopo di questo sito?

Nel mio caso la scansione diretta non ha avuto successo: Nmap ha segnalato "Host seems down", probabilmente perché la rete del laboratorio blocca i probe ICMP usati di default per verificare se l'host è raggiungibile (si potrebbe risolvere aggiungendo l'opzione -Pn per saltare il controllo di reachability). Visitando il sito scanme.nmap.org da browser, però, l'host è risultato regolarmente online: la pagina conferma che è un server messo a disposizione dal progetto Nmap proprio per testare scansioni, con l'invito esplicito a non sovraccaricarlo con troppe scansioni al giorno.

DOMANDA DI RIFLESSIONE

Come può Nmap aiutare con la sicurezza della rete? Come può Nmap essere usato da un attore malevolo come strumento nefasto?

Lato difensivo, Nmap aiuta a fare l'inventario della propria rete, scoprire dispositivi non autorizzati, verificare quali porte e servizi sono esposti e individuare versioni di software obsolete da aggiornare prima che diventino un problema. Lo stesso strumento, usato da un attaccante, diventa la prima fase di un attacco: la ricognizione. Una scansione come quella fatta in questo laboratorio permette di mappare host attivi, porte aperte e versioni dei servizi, informazioni che servono poi per cercare exploit specifici per quella versione di software, esattamente come succede negli attacchi reali contro Metasploitable.

CONCLUSIONI

Questo bonus mi ha fatto vedere Nmap sia come strumento di audit sia come prima fase di un attacco. La parte più interessante è stata proprio l'imprevisto con scanme.nmap.org: non sempre una scansione fallita significa host spento, a volte significa solo che il controllo di reachability di Nmap (il ping) viene bloccato, e va tenuto a mente quando si analizzano i risultati di una scansione.

BONUS 2: ATTACCO A UN DATABASE MYSQL

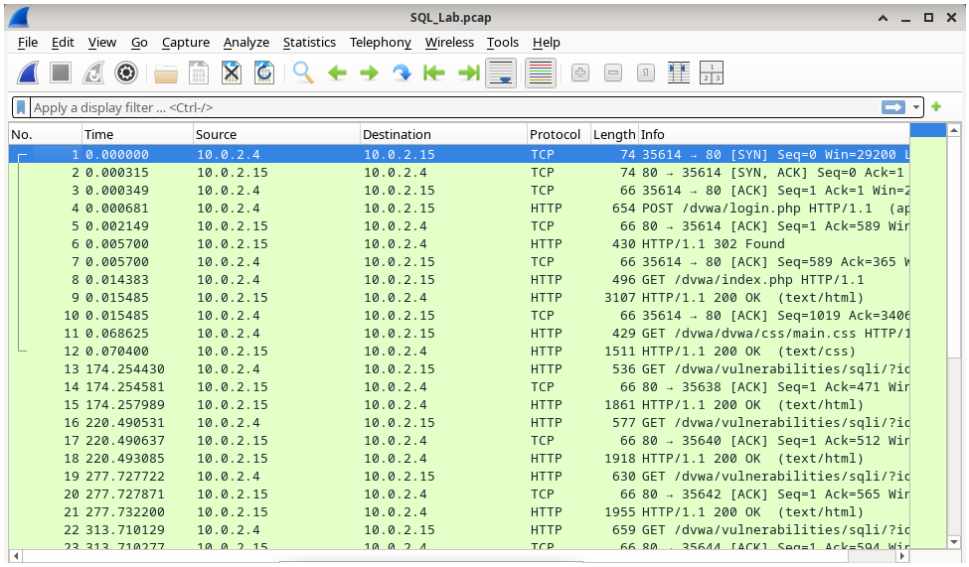
CONTESTO

Gli attacchi di SQL Injection permettono a un aggressore di inserire istruzioni SQL in un sito web e ricevere risposte direttamente dal database. In questo laboratorio ho analizzato con Wireshark un file PCAP (SQL_Lab.pcap) che cattura un attacco di SQL injection già avvenuto contro un'applicazione vulnerabile (DVWA), per ricostruire passo dopo passo cosa ha fatto l'aggressore.

SVOLGIMENTO

PARTE 1 E 2: APERTURA DEL PCAP E PRIMO TENTATIVO DI SQL INJECTION

Ho aperto il file SQL_Lab.pcap con Wireshark e individuato, seguendo il flusso HTTP (Follow > HTTP Stream) dei vari pacchetti, le richieste GET inviate dall'aggressore all'host 10.0.2.15.



Vista generale del traffico catturato in SQL_Lab.pcap: login su DVWA seguito da diverse richieste verso la pagina vulnerabile sqli/?id=.

Nel primo flusso analizzato, l'aggressore ha inserito la query 1' or 1=1 union select user, password from users# nel campo UserID della pagina vulnerabile. Invece di rispondere con un messaggio di fallimento del login, l'applicazione ha risposto con un record di un database.



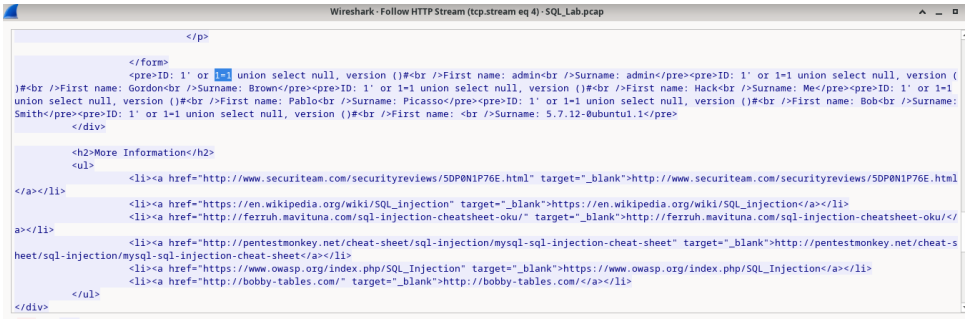
Primo test di SQL injection (1=1): l'applicazione restituisce un record reale invece di un errore.

Cosa ha fatto l'aggressore in questo passaggio?

L'aggressore ha verificato se l'applicazione è vulnerabile alla SQL injection inserendo la stringa 1=1, che crea un'istruzione SQL sempre vera. Invece di rispondere con un messaggio di fallimento del login, l'applicazione ha risposto con un record di un database, confermando che il campo non sta validando correttamente l'input e che qualsiasi cosa inserita lì verrà eseguita come codice SQL.

PARTE 3 E 4: LA SQL INJECTION CONTINUA E FORNISCE INFORMAZIONI DI SISTEMA

Proseguendo con i flussi successivi, l'aggressore ha affinato la query per estrarre informazioni più specifiche sul database, prima la versione e poi il nome del database e l'utente in uso.



Query 1' or 1=1 union select null, version()# usata per estrarre la versione del DBMS.

Qual è la versione?

Il database in uso è MySQL versione 5.7.12-0ubuntu1.1, come si legge nel campo Surname restituito dalla query union select null, version().



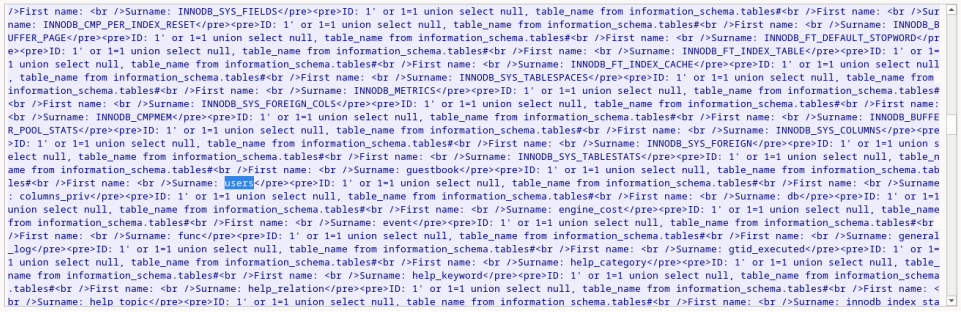
Query con database() e user(): il database si chiama dvwa e l'utente è root@localhost.

Il nome del database è e l'utente del database è

Il nome del database è dvwa e l'utente con cui l'applicazione si collega al database è root@localhost. Usare l'utente root per una semplice applicazione web è una pessima pratica di sicurezza, perché in caso di SQL injection l'aggressore eredita i privilegi più alti possibili sul database.

PARTE 5: ENUMERAZIONE DELLE TABELLE

Sapendo che il database contiene altre tabelle oltre a quella di login, l'aggressore ha modificato la query in 1' or 1=1 union select null, table_name from information_schema.tables# per elencarle tutte.



Enumerazione delle tabelle tramite information_schema.tables, tra cui la tabella users.

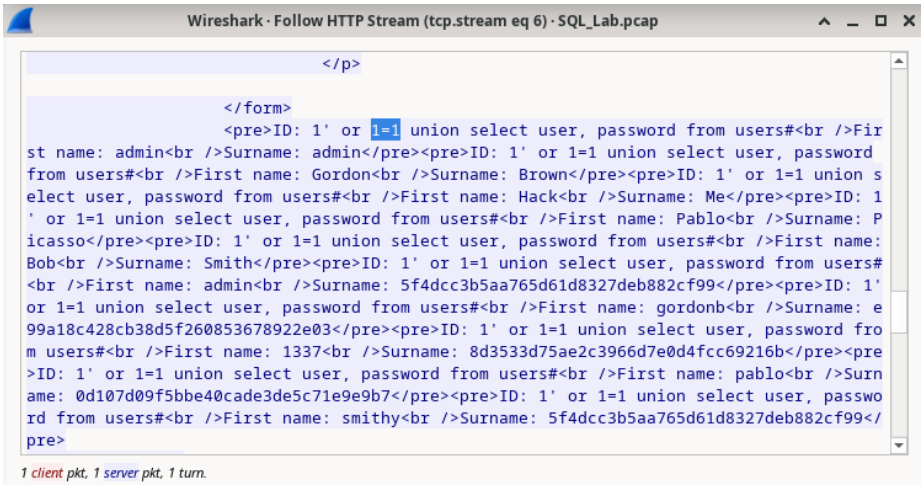
Cosa farebbe per l'aggressore il comando modificato con {1' OR 1=1 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users'}?

Questa variante della query non elenca più le tabelle ma le colonne della tabella users, filtrate proprio sul nome di quella tabella. È il passo logico successivo dell'enumerazione: prima si scoprono le tabelle

interessanti (come users), poi si scoprono i nomi esatti delle colonne (ad esempio user_id, password, first_name) per sapere come comporre la query finale che estrae i dati veri e propri.

PARTE 6: ESTRAZIONE DEGLI HASH DELLE PASSWORD

Con il nome della tabella e i nomi dei campi ormai noti, l'aggressore ha lanciato la query finale 1' or 1=1 union select user, password from users#, che restituisce direttamente username e hash della password di ogni utente registrato in DVWA.

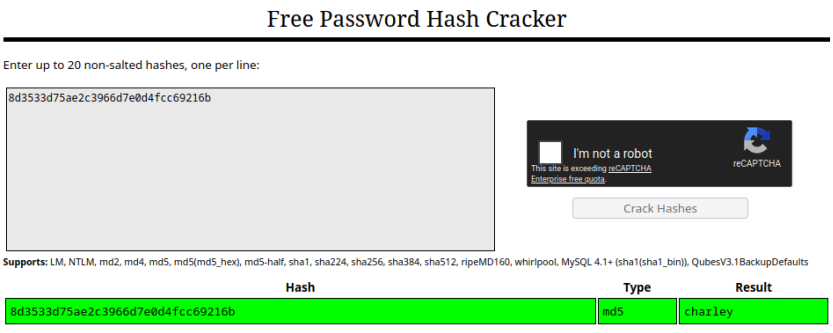


Estrazione di username e hash della password dalla tabella users tramite UNION SELECT.

Quale utente ha l'hash della password 8d3533d75ae2c3966d7e0d4fcc69216b?

L'hash 8d3533d75ae2c3966d7e0d4fcc69216b appartiene all'utente 1337 (uno degli account presenti nel database DVWA).

Ho copiato l'hash su un sito di cracking online (crackstation.net) per decifrarlo.



L'hash MD5 viene craccato e rivela la password in chiaro: charley.

Risultato del cracking dell'hash

L'hash è di tipo MD5 e una volta craccato rivela la password in chiaro charley. Questo conferma quanto sia rischioso salvare le password in chiaro senza salt: un hash MD5 non salato può essere craccato in pochi secondi con un database di hash precalcolati (rainbow table).

DOMANDE DI RIFLESSIONE

Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?

I siti web sono comunemente basati su database e utilizzano il linguaggio SQL. La gravità di un attacco di SQL injection dipende dall'aggressore: come visto in questo laboratorio, con poche query mirate si può arrivare a leggere l'intero contenuto di una tabella, inclusi username e password hash, semplicemente perché l'input dell'utente non viene validato prima di essere inserito nella query.

Quali sono 2 metodi o passaggi che possono essere adottati per prevenire gli attacchi di SQL injection?

Le risposte possono variare, ma dovrebbero includere: validare e filtrare sempre l'input dell'utente, usare query parametrizzate o stored procedure invece di costruire query concatenando stringhe, applicare il principio del privilegio minimo (l'utente del database non dovrebbe mai essere root), disabilitare funzionalità del database non necessarie e, dove possibile, usare un Web Application Firewall come ulteriore livello di protezione.

CONCLUSIONI

Analizzare un attacco di SQL injection già catturato in un PCAP, invece di eseguirlo direttamente, mi ha aiutato a vedere la cosa dal punto di vista difensivo: seguendo i flussi HTTP in Wireshark si vede esattamente come un aggressore costruisce la propria query passo dopo passo, partendo da un test banale (1=1) fino ad arrivare al furto di credenziali vere. È un buon promemoria del perché input non validato e privilegi eccessivi sul database (come l'uso di root) siano due dei problemi più comuni dietro violazioni di questo tipo.